

Gouvernance des SI

GOUVERNANCE DES SI

Qu'est ce que la Gouvernance ?

- ❖ Le terme « **Gouvernance** » désigne la capacité d'une organisation à être en mesure de contrôler et de réguler son propre fonctionnement afin d'éviter les conflits d'intérêts liés à la séparation entre :
 - les ayants-droits (actionnaires, direction, conseil d'administration)
 - et les acteurs (employés, les fournisseurs, les clients, les banques, l'environnement...).
 - ❖ Il s'agit de privilégier le partenariat entre les différents acteurs.
 - ❖ C'est l'art de **bien gouverner.**
-

Gouvernance des Systèmes d'information

La « **Gouvernance des Systèmes d'Information** », renvoie aux moyens de gestion et de régulation des Systèmes d'Information (SI) mis en place dans une entreprise pour atteindre ses objectifs :

- ❖ Audit,
- ❖ Bonnes pratiques,
- ❖ Tableaux de bord,
- ❖ Benchmarking,
- ❖ Certification...

Gouvernance des Systèmes d'information

La Gouvernance du SI est un processus de management, fondé sur des bonnes pratiques, qui permet à l'entreprise d'optimiser ses investissements informatiques dans le but de :

- ✓ Contribuer à ses objectifs de création de valeur
- ✓ Accroître la performance des processus informatiques et leur orientation clients
- ✓ Maîtriser les aspects financiers du système d'information
- ✓ Développer les solutions et les compétences en SI dont l'entreprise aura besoin dans le futur
- ✓ Garantir que les risques liés au système d'information sont sous contrôle

....tout en développant la transparence.

Gouvernance des Systèmes informatiques

- ❖ La Gouvernance des systèmes informatiques ou des Technologies de l'Information (IT Governance) est axée sur la technologie de l'information et de la communication.
- ❖ Cette discipline, en phase avec les objectifs de l'entreprise, s'intéresse plus particulièrement à :
 - la gestion des risques,
 - l'optimisation des investissements et des ressources,
 - la création de valeurs
 - la performance des technologies de l'information.

Il s'agit d'une démarche de Management.

Governance des SI: Orienter, Evaluer et Surveiller

- ❑ De nombreuses entreprises gèrent des actifs (personnes, argent, usines et relations clients), mais la technologie de l'information qui collecte, stocke et diffuse leurs données sur ces actifs les laisse perplexes.
- ❑ Pendant de nombreuses années, certaines entreprises ont réussi, malgré la faiblesse des pratiques de gestion des TI, mais ce n'est plus possible.



Gouvernance des SI: Orienter, Evaluer et Surveiller

- ❑ "Les entreprises dont la gouvernance des pratiques informatiques est supérieure à la moyenne et qui poursuivent une stratégie spécifique génèrent 20% de bénéfices en plus que celles dont la gouvernance est médiocre "
- ❑ Quelle est la gouvernance de l'informatique? Avant, nous pouvons examiner ce qu'est la gouvernance d'entreprise.



Gouvernance des SI: Orienter, Evaluer et Surveiller

- ❑ Dans la plupart des pays, le gouvernement d'entreprise devient un conseil de surveillance chargé de protéger les intérêts des actionnaires et des autres parties prenantes telles que les employés, les clients, les créanciers, etc.
 - ❑ Le conseil travaille avec une équipe de gestionnaires pour mettre en œuvre les principes de gouvernance afin de garantir l'efficacité des processus organisationnels.
 - ❑ "Il n'y a pas de modèle unique de gouvernance d'entreprise"
-

Gouvernance des SI: Orienter, Evaluer et Surveiller

Gouverner c'est:

- La pratique du contrôle du comportement, des activités, des processus par:
 - Créer un mécanisme de contrôle définissant les rôles, les responsabilités, les droits de décision et les obligations
 - Définir des règles (politique)
 - Définir des limites pour restreindre le comportement
 - Réagir aux changements et ajuster les nouvelles fonctionnalités
 - Orienter (déléguer), Évaluer et surveiller
-

Gouvernance des SI: Orienter, Evaluer et Surveiller

- ❑ La gouvernance des SI relève de la responsabilité des membres de la haute direction et de la direction. Elle comprend la direction, les structures organisationnelles et les processus qui garantissent que l'informatique de la société préserve et étend les objectifs et les stratégies de l'entreprise. (Governance Institute COBIT, définition orientée processus)
 - ❑ La gouvernance informatique consiste à spécifier les droits de décision et le cadre de responsabilité afin de produire le comportement souhaitable dans l'utilisation des technologies de l'information. (Weill & Ross. Gouvernance des TI. Définition axée sur le comportement)
-

Gouvernance des SI: Orienter, Evaluer et Surveiller

- ❑ La gouvernance informatique est l'allocation des responsabilités et la conception de l'organisation informatique, visant à une utilisation efficiente et efficace de l'informatique dans les processus métiers et au respect des règles internes et externes.
 - ❑ Responsabilité: les individus, les organisations et les communautés sont responsables de leurs actions et peuvent être amenés à les expliquer aux autres. On leur attribue une confiance ou un devoir en fonction de leur poste.
 - ❑ Règles: politiques et principes guidant l'action
-

Quelques référentiels de gouvernance des SI

- ❑ **ITIL** : IT Information Library :
Cadre de référence proposé par l'Office of Government Commerce du Royaume-Uni rassemblant, dans un ensemble de guides, les meilleures pratiques en matière de management des services informatiques.
- ❑ **CobiT** : Control Objectives for Information and Technologies :
Méthodologie d'évaluation des services informatiques au sein de l'entreprise, publiée en 1996 par l'IT Governance Institute et l'ISACA (Information Systems Audit and Control Association)
- ❑ **CMMI** : Capability Maturity Model Integration :
Référentiel d'évaluation de la capacité à gérer et terminer un projet correctement, proposant nombre de bonnes pratiques liées à la gestion, au développement et à la maintenance d'applications et de systèmes. Ces bonnes pratiques sont regroupées en 24 processus, eux-mêmes regroupés en 4 types (Process Management, Project Management, Engineering et Support) et 5 niveaux de maturité.
- ❑ **Val IT** :
Ensemble structuré de pratiques clés comportant deux volets : un aspect risques, qui conduit à des pratiques d'audit et à des référentiels de bonnes pratiques comme CobiT.
- ❑ **ISO /IEC 38500** :
Cette norme établit des définitions, des principes et un modèle de bonne gouvernance informatique d'entreprise. Concernant l'attitude recommandée pour guider la prise de décision. Elle énonce six principes:
responsabilité
stratégie
acquisition
exécution
conformité
comportement humain.

Quelques référentiels de gouvernance des SI

- ❑ COBIT 4 et ITIL sont actuellement considérés comme des cadres de gestion, PAS des cadres de gouvernance.
- ❑ Il en va de même pour la norme ISO / IEC 20000, qui est également une normalisation de la gestion des services.
- ❑ Il n'existe qu'une norme en matière de gouvernance informatique: la norme ISO / IEC 38500, récemment adoptée par COBIT 5.

➤ *Carlos Juiz et Mark Toomey. Pour gouverner l'informatique, ou ne pas gouverner l'informatique?. Communications de ACM 58, 2 (février 2015), p. 58-64, 2015.*

COBIT : pourquoi ?

Le **Cobit** (“**C**ontrol des **o**bjectifs des **t**echnologies de l’**i**nformation”), a été développé en 1994 par l'ISACA (The Information System Audit and Control Association) et est un outil puissant qui a été conçu suite au constat suivant :

- **Constat** : Le fonctionnement de la majorité des grandes entreprises, aujourd'hui, repose complètement sur le traitement de l'information.
 - **Nécessité** : Il est vital, pour leur avenir, que le système d'information soit en cohérence avec les objectifs et la stratégie globale de l'entreprise.
 - **Volonté des dirigeants** : Le SI doit apporter de la valeur ajoutée et de la performance dans l'organisation.
-

Le COBIT

Le COBIT est un référentiel de gouvernance des systèmes d'information qui décompose tout système informatique en

- ❖ 34 **processus** répartis en
 - ❖ 4 **domaines** fonctionnels permettant de couvrir
 - ❖ 318 **objectifs**.

COBIT : Les acteurs concernés

Les principaux acteurs concernés par le Cobit sont :

- ❖ Les auditeurs
 - ❖ Les responsables des SI
 - ❖ La Direction Générale
 - ❖ Les Directions métiers
-

COBIT : Les 4 Domaines

- ❖ **Planning et organisation** (10 processus) :
Comment utiliser les technologies afin que l'entreprise atteigne ses objectifs ?
 - ❖ **Acquisition et mise en place** (7 processus) :
Comment définir, acquérir et mettre en œuvre des technologies en adéquation avec les objectifs de l'entreprise ?
 - ❖ **Fourniture du service et support** (13 processus) :
Comment garantir l'efficacité des systèmes technologiques en action ?
 - ❖ **Surveillance** (4 processus) :
Comment s'assurer que la solution mise en œuvre corresponde bien aux besoins de l'entreprise dans une perspective stratégique ?
-

COBIT : Objectifs et Ressources

Les **objectifs** du Cobit sont les suivants :

- L'efficacité (résultats/objectifs),
- L'efficience (résultats/ressources),
- La confidentialité,
- L'intégrité,
- La disponibilité,
- La conformité,
- La fiabilité.

Pour atteindre ces objectifs, le SI dispose des **ressources** suivantes :

- Les compétences,
 - Les applications,
 - Les technologies,
 - Les données.
-

COBIT : Cartographie – Exemple de représentation

- ❖ Représentation des processus, des objectifs et des ressources.
- ❖ L'impact du processus sur le critère d'information peut être Primaire, Secondaire, ou vide.
- ❖ Le lien entre les processus et les ressources ne mesure pas le niveau d'utilisation, mais le niveau de management de la ressource par le processus COBIT

DOMAIN	PROCESS	Information Criteria							IT Resources				
		effectiveness	efficiency	confidentiality	integrity	availability	compliance	reliability	people	applications	technology	facilities	data
Planning & Organisation	PO1 Define a strategic IT plan	P	S						✓	✓	✓	✓	✓
	PO2 Define the information architecture	P	S	S	S					✓			✓
	PO3 Determine technological direction	P	S								✓	✓	
	PO4 Define the IT organisation and relationships	P	S						✓				
	PO5 Manage the IT investment	P	P					S	✓	✓	✓	✓	
	PO6 Communicate management aims and direction	P				S			✓				
	PO7 Manage human resources	P	P						✓				
	PO8 Ensure compliance with external requirements	P					P	S	✓	✓			✓
	PO9 Assess risks	P	S	P	P	P	S	S	✓	✓	✓	✓	✓
	PO10 Manage projects	P	P						✓	✓	✓	✓	
	PO11 Manage quality	P	P		P		S		✓	✓	✓	✓	

Les niveaux de maturité : de 0 à 5

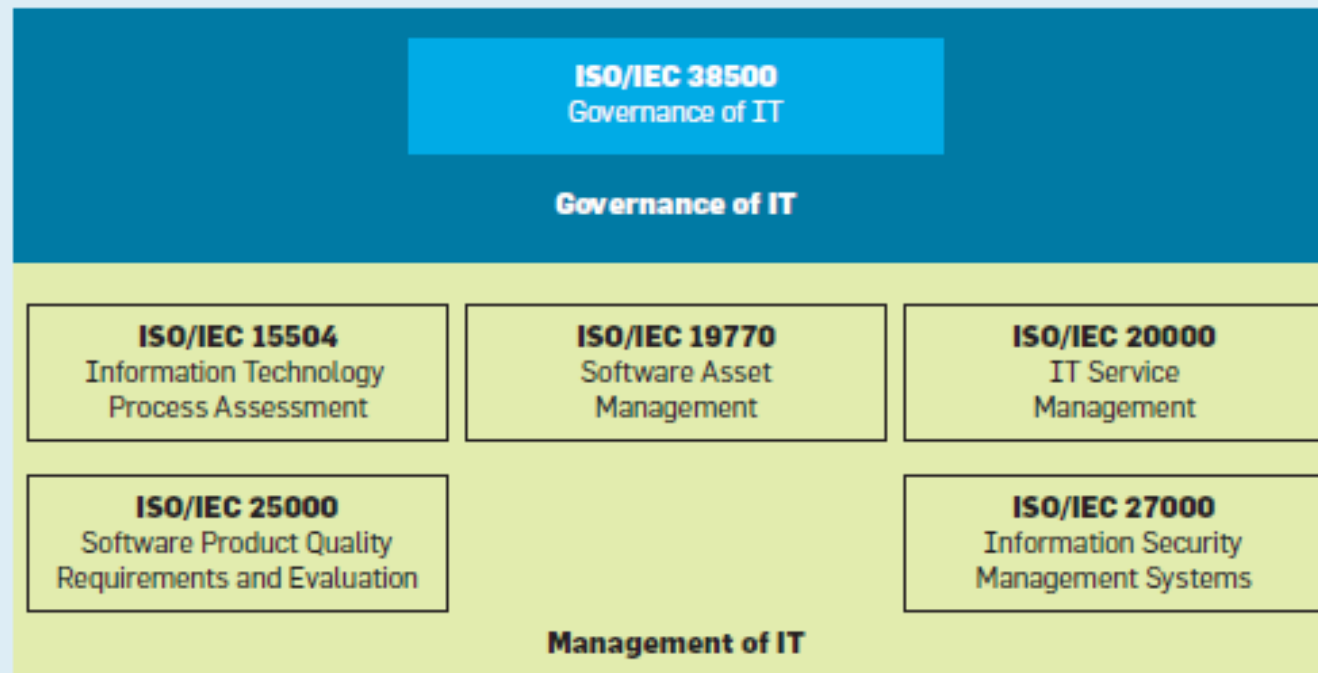
- **Inexistant** : Pas de processus / Entreprise non consciente
 - **Initial** : quelques processus / Entreprise prend conscience
 - **Répétitif** : Processus avec modèle répétable / Entreprise traite au cas par cas
 - **Défini** : Processus formalisés, pas de responsabilités définies, pas de suivi qualité
 - **Géré et mesurable** : Processus surveillés, Responsabilités définies, suivi de la qualité, Personnel formé
 - **Optimisé** : Amélioration du processus existant, l'entreprise assure une veille afin de mettre à jour ses méthodes
-

Qu'apporte COBIT ?

- ❖ Des processus plus simples et plus compréhensibles.
 - ❖ Une vision compréhensible par les métiers de ce que fait l'informatique.
 - ❖ De la valeur ajoutée des systèmes d'information.
 - ❖ Un meilleur alignement de l'informatique sur l'activité de l'entreprise (orientation métier).
 - ❖ Une attribution claire des responsabilités (approche par processus).
 - ❖ Une aide à la décision, aux choix, aux investissements...
 - ❖ Une possibilité d'élaborer son propre standard COBIT afin d'être encore plus en phase avec les objectifs de l'entreprise en terme de systèmes d'information.
 - ❖ Une auto évaluation
 - ❖ Une comparaison avec d'autres entreprises ayant un même domaine métier
-

Les Standards ISO/IEC

Figure 1. Main ISO/IEC standards of IT management and governance of IT.



Le standard ISO/IEC 38500

- ❑ Les technologies de l'information (TI) sont devenues omniprésentes dans le soutien et la mise en œuvre de la stratégie des entreprises et cette prévalence oblige la gouvernance des TI à constituer un impératif organisationnel.
 - ❑ Les entreprises ont considérablement investi dans l'informatique pour automatiser leurs processus métier et pour communiquer et traiter électroniquement avec leurs clients et leurs fournisseurs.
-

Le Standard ISO/IEC 38500

- ❑ Malheureusement, les avantages découlant de ces investissements ne se sont pas toujours matérialisés et, dans certains cas, les entreprises ont subi des dommages financiers et une atteinte à leur réputation en raison de défaillances informatiques. Cela a renforcé la prise de conscience des instances dirigeantes de la nécessité d'une gouvernance informatique et de leurs responsabilités à cet égard.
 - ❑ Il se peut toutefois que certains organes directeurs ne sachent pas quels arrangements ils doivent mettre en place pour la gouvernance des technologies de l'information.
-

Le Standard ISO/IEC 38500

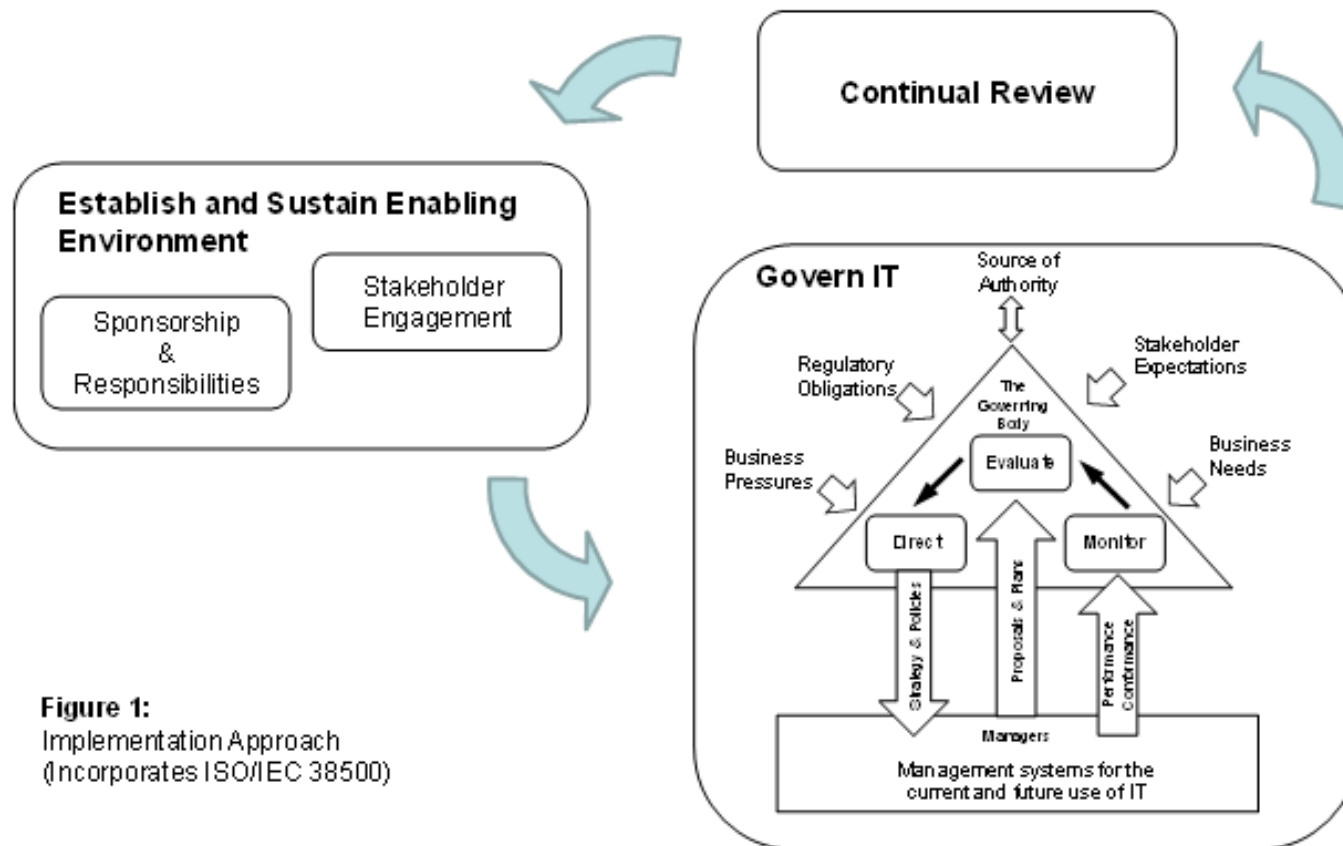
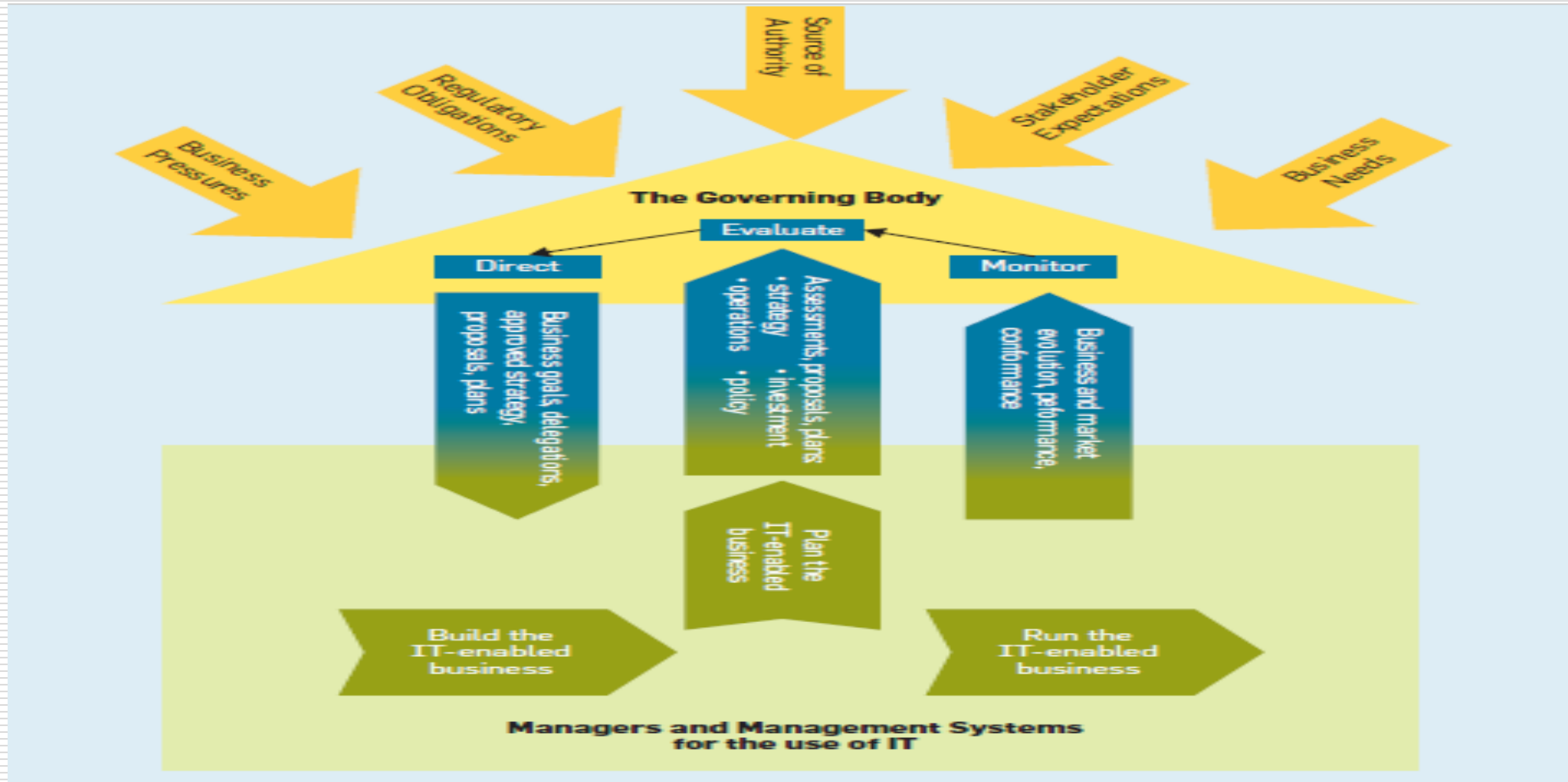


Figure 1:
Implementation Approach
(Incorporates ISO/IEC 38500)

Le Standard ISO/IEC 38500

- Les trois activités du modèle de gouvernance de l'ISO / CEI 38500, à savoir évaluer, diriger et surveiller, ont lieu pendant la phase de gouvernance. Celles-ci sont encadrées et guidées par les six principes de la norme (**responsabilité, stratégie, acquisition, performance, conformité, comportement humain**) dans le contexte des environnements internes et externes, ainsi que par la culture de l'organisation en matière de gouvernance informatique.
-

Modèle de l'ISO/IEC 38500



Le Standard ISO/IEC 38500

- ❑ Il est important de définir et de décrire le résultat de la gouvernance informatique lors de l'application du cadre ISO / IEC 38500, plutôt que d'être orienté processus ou contrôle. Cela garantira que l'organe directeur détermine ce qui doit être réalisé, plutôt que de spécifier la manière dont cela doit être fait, guidant ainsi de manière appropriée l'organisation ou l'utilisation du système informatique.
 - ❑ En outre, un mécanisme d'évaluation approprié est nécessaire, qui doit prendre en compte la nature basée sur les principes de l'ISO / CEI 38500.
-

Principes de l'ISO/IEC 38500

Responsabilité

- ❑ Les individus et les groupes au sein de l'organisation comprennent et acceptent leurs responsabilités en ce qui concerne à la fois l'offre et la demande de technologies de l'information. Les personnes responsables d'actions ont également le pouvoir de les exécuter.
-

Principes de l'ISO/IEC 38500

Tableau B.1: Critères d'évaluation du principe de responsabilité

Résultats bénéfiques	Preuve de succès
L'organisation met en œuvre avec succès le changement commercial rendu possible par l'informatique	Les cadres dirigeants dirigent les processus métier, la structure organisationnelle et le changement humain lors de la mise en œuvre de solutions informatiques
La valeur organisationnelle est générée par les TI	Les cadres dirigeants considèrent l'informatique comme un investissement rentable, et pas uniquement comme un coût à réduire.
L'organisation reçoit la qualité des services dont elle a besoin de la manière la plus efficace et efficiente possible	Les dirigeants déterminent le meilleur modèle de prestation informatique en prenant en compte: • Droits de décision et structures de contrôle (central, décentralisé, fédéral, etc.) • Offre: Optimisation de l'offre de TI (stratégie d'approvisionnement)

Principes de l'ISO/IEC 38500

Strategie

- ❑ La stratégie commerciale de l'entreprise prend en compte les capacités actuelles et futures du service informatique;
 - ❑ Les plans stratégiques informatiques répondent aux besoins actuels et continus de la stratégie commerciale de l'organisation.
-

Principes de l'ISO/IEC 38500

Tableau B.2: Critères d'évaluation du principe de la stratégie

Résultats bénéfiques	Preuve de succès
Les activités de l'organisation sont efficacement prises en charge par les TI et le changement stratégique est bien opéré par les TI.	L'informatique est clairement alignée sur la stratégie et l'architecture de l'entreprise
Les systèmes d'aide à la décision de l'organisation fournissent des informations rapides et de haute qualité	Les exigences opérationnelles en matière de convivialité, de confidentialité, d'intégrité et de disponibilité des données utilisées pour prendre des décisions sont identifiées et satisfaites.
Les objectifs de l'organisation sont concrétisés par l'innovation informatique	L'IT est utilisé pour: • Activer, perturber et redéfinir les modèles commerciaux • S'engager et communiquer avec les clients

Principes de l'ISO/IEC 38500

Acquisition :

- ❑ Les acquisitions informatiques sont effectuées pour des raisons valables, sur la base d'une analyse appropriée et continue, avec une prise de décision claire et transparente. Il existe un équilibre approprié entre les avantages, les opportunités, les coûts et les risques, à court et à long terme.
-

Principes de l'ISO/IEC 38500

Tableau B.3: Critères d'évaluation pour le principe de l'acquisition

Résultats bénéfiques	Preuves de Succès
Les investissements dans l'informatique ont été définis en priorité pour déterminer dans quelle mesure leur contribution potentielle à l'activité est à la fois attractive et réalisable.	Investissements informatiques structurés en portefeuilles, rendements des investissements nécessaires pour respecter les taux de rendement minimaux
Les besoins métier sont entièrement pris en charge par des solutions informatiques sélectionnées	Le processus d'approvisionnement des solutions informatiques garantit que les exigences en matière de fonctionnalité, de convivialité, d'architecture, de sécurité, de performance, de disponibilité, etc. sont atteintes
Les programmes de mise en œuvre se déroulent conformément au plan et procurent des avantages commerciaux	Programmes de changement structurés pour fournir des capacités commerciales avec une gestion minutieuse des coûts, des risques, du calendrier et des avantages

Principes de l'ISO/IEC 38500

Performance :

- ☐ Le service informatique est parfaitement adapté au soutien de l'organisation, en fournissant les services, les niveaux de service et la qualité de service requis pour répondre aux exigences commerciales actuelles et futures
-

Principes de l'ISO/IEC 38500

Tableau B.4: Critères d'évaluation du principe de Performance

Résultats bénéfiques	Preuves de Succés
Toutes les parties prenantes capables d'interagir et de traiter avec des systèmes informatiques fournissant les services, les niveaux de service et la qualité de service répondant à leurs exigences	Les TI sont suffisamment réactives et disponibles, même en cas de forte demande ou de sinistre. Les changements et les mises à niveau informatiques ne sont effectués qu'avec une interruption planifiée de l'activité.
L'information est complète, précise, sécurisée et accessible	Le service informatique est protégé contre les accès non autorisés et les modifications de données. Contrôles en place pour assurer l'intégrité des données
Les parties prenantes ont apporté une aide efficace lors de la demande d'assistance informatique	Un centre de services efficace qui résout les demandes, les incidents et les problèmes et veille à ce que les clients soient assistés dans les niveaux de service définis

Principes de l'ISO/IEC 38500

Conformité (Conformance) :

- ❑ Les TI sont conformes à toutes les lois et à tous les règlements obligatoires. Les politiques et les pratiques sont clairement définies, mises en œuvre et appliquées.
-

Principes de l'ISO/IEC 38500

Tableau B.5: Critères d'évaluation du principe de conformité

Résultats bénéfiques	Preuves de Succès
Les politiques, règles et mandats de l'organisation sont mis en œuvre avec précision par le service informatique	Processus et contrôles informatiques matures en place, garantissant la conformité aux politiques organisationnelles, aux exigences de service et à l'appétence pour le risque
L'organisation gère correctement ses informations et ses transactions afin d'éviter toute violation des exigences légales et / ou réglementaires	Surveillance continue de la législation pertinente, mise en œuvre des processus et contrôles informatiques nécessaires et fourniture d'une assurance indépendante

Principes de l'ISO/IEC 38500

Comportement humain (Human Behaviour) :

- ❑ Les politiques, pratiques et décisions informatiques témoignent du respect du comportement humain, y compris des besoins actuels et en évolution de tous les «acteurs du processus».
-

Principes de l'ISO/IEC 38500

Tableau B.6: Critères d'évaluation du principe de comportement humain

Résultats bénéfiques	Preuves de Succès
Les parties prenantes utilisent les TI de l'organisation de manière acceptable.	Les gestionnaires exécutifs assurent le leadership, s'appuyant sur une éducation, une formation et un suivi de la conformité aux politiques appropriés pour les utilisateurs et les fournisseurs de services.
Efficacité commerciale et valeur générée par le personnel utilisant les TI de manière productive et efficace	Formation continue, formation et tests de compétences pour tous les utilisateurs sur tous les aspects de l'utilisation des TI de l'organisation
